

Cloud Security: Challenges, Solutions, and Best Practices

What is Cloud Security?

Cloud security is a set of security measures designed to protect cloud-based infrastructure, applications, and data. The goal is to establish control over data and resources, prevent unauthorized access, protect data privacy, prevent malicious attacks by external hackers or insider threats, and protect cloud workloads from accidental or malicious disruption. Another objective of cloud security is to extend an organization's compliance policies to the cloud.

This is part of an extensive series of guides about [data breaches](#).

The Need for Cloud Security: Cloud Security Challenges

Cloud Misconfigurations

A misconfigured system or network can provide an attacker with an entry point, allowing them to move laterally within the network and gain unauthorized access to sensitive resources. Misconfigurations can be the result of lack of security awareness during configuration of cloud systems, human error, or improperly defined automation templates.

Data Privacy and Confidentiality

Data privacy and confidentiality are major concerns for many organizations. Data protection regulations such as the EU General Data Protection Regulation (GDPR), the US Health Insurance Interoperability and Accessibility Act (HIPAA), and the Payment Card Industry Data Security Standard (PCI DSS), require organizations to protect customer data. Most organizations also have sensitive or confidential data that is not covered by compliance standards, but would be extremely damaging to the business if exposed.

Moving data to the cloud has many benefits, but also poses serious security concerns. Cloud-based storage services are often exposed to public networks by default, and if not

properly secured, can make data easily accessible by attackers.

Many organizations migrating data and workloads to the cloud lack the expertise to ensure it is securely configured and deployed. This creates the risk that sensitive data moved to the cloud will be compromised, leading to expensive audits, compliance fines, and reputational damage.

Social Engineering and Credential Theft

Threat actors often use cloud applications and environments as part of social engineering attacks. With the growing use of cloud-based email and document sharing services (such as G-Suite, Google Drive, Office 365, and OneDrive), it is easy for attackers to trick employees into granting access to sensitive data. All that is needed is to send a link requesting access to content, and provide a good excuse for the user to grant access.

There are many ways cybercriminals can compromise employee credentials to cloud services. Securing identities on the cloud is a major problem for organizations, because compromised identities can expose the privacy and security of critical cloud-based data and resources.

Specific Compliance Requirements

Most data protection standards require organizations to demonstrate that they properly restrict access to protected information (such as credit card data or medical patient records). This may require creating physical or logical isolation in an organization's network, ensuring that protected data can only be accessed by authorized employees.

Cloud deployments provide limited visibility and control over the infrastructure, and are also structured differently from traditional data centers. This can make it more difficult to achieve and demonstrate these types of compliance requirements in the cloud.

Types of Cloud Security Solutions

The following are common types of solutions you can use to secure your cloud.

Cloud Access Security Broker (CASB)

CASB is a security policy enforcement point deployed between cloud service consumers and cloud service providers. It is responsible for enforcing corporate security policies when users access cloud-based resources. CASB can handle several types of security policies, including:

- Authentication and authorization
- Single sign-on
- Credential mapping
- Device analysis
- Encryption
- Tokenization
- Logging and alerting
- Malware detection and prevention

Cloud Workload Protection Platform (CWPP)

CWPP is a workload-centric security product that protects workloads—applications or other resources—running on one or more virtual machines (VMs), containers, or serverless functions. The unique aspect of CWPP is that it sees and protects a workload as a single unit, even if it runs on multiple servers or cloud instances across multiple clouds or data centers.

CWPP capabilities typically include:

- System hardening and system integrity monitoring
- Vulnerability management
- Host-based segmentation
- Application control
- Visibility of workload security across hybrid environments
- Central control of workload security from a single console

Cloud Security Posture Management (CSPM)

CSPM solutions continuously manage cloud security risks. They can detect, log, and report security issues, and in some cases, automatically remediate them. These issues can include misconfiguration of cloud services, improper security settings, resource governance issues, and compliance violations.

A CSPM solution focuses on four main areas:

1. Asset inventory and classification
2. Identity, security and compliance
3. Monitoring and analysis
4. Cost management and resource organization

Learn more in our [detailed guide to CSPM](#).

Cloud Infrastructure Entitlement Management (CIEM)

CIEM is an extension of cloud-based Identity and Access Management (IAM). IAM is the basis for managing identity and access in all public cloud platforms, however, it quickly becomes too complex to manage using first-party cloud provider tools.

CIEM solutions can address this complexity by providing centralized identity and access governance controls. The goal is to reduce privileges to minimum on critical cloud infrastructure, and simplify least privilege access control in dynamic distributed environments.

Cloud-Native Application Protection Platform (CNAPP)

CNAPP is a new category that converges CSPM and CWPP solutions into one platform. A CNAPP solution secures workloads and hosts such as VMs, containers, and serverless functions, allowing organizations to remediate vulnerabilities and misconfigurations, detect threats in production environments, investigate, and actively respond to them.

Cloud Security Best Practices

Understand the Shared Responsibility Model

Cloud vendors operate under a shared responsibility model that distributes security responsibilities between the vendor and the customer. Typically, the cloud vendor is responsible for securing the underlying infrastructure, while the cloud customer is responsible for securing their workloads and data hosted on the cloud infrastructure.

However, responsibilities vary between delivery models such as Software as a Service (SaaS), Platform as a Service (PaaS), and Infrastructure as a Service (IaaS). Typically, the greater control you gain over the infrastructure, the more responsibility you share for securing the environment.

Perform Regular Audits and Penetration Testing

Penetration testing is a simulated, authorized attack performed by ethical hackers to identify and fix security gaps. It can help you assess the security controls of your cloud infrastructure and fix any vulnerabilities and weaknesses discovered. Regular audits are a security best practice and often also a requirement by regulatory authorities to ensure compliance and

security. It helps verify the validity of cloud security measures—yours and those configured by your cloud vendor.

Secure User Endpoints

Cloud environments allow endpoints to connect with the environment in various ways, typically by using web browsers. Organizations can protect their workloads and data by implementing client-side security to keep end-user browsers updated and secure. You can use a combination of firewalls, Internet security tools, antivirus, intrusion detection tools, mobile device security, and endpoint security solutions to protect your network against endpoint threats.

Set Up Backup and Recovery Solutions

As per the shared responsibility model, cloud vendors provide durability and high availability. However, these capabilities do not prevent data loss. Backup and recovery solutions help ensure there is sufficient data available for recovery, preventing data loss during ransomware infections, accidental or malicious data deletion and modification, and hardware failures.

Organizations can implement various strategies for backup, recovery, and archiving. Automated backups and lifecycle policies can help retain recoverable copies. Archives enable you to store infrequently used data in separate, and secure storage. Recovery procedures define how data should be restored in case of a disaster or security event and the roles responsible for managing this process.

Cloud Security with HackerOne

Migrating code, apps, and assets to the cloud environment create new risks. HackerOne's consolidated platform addresses the cloud security risks by calling on a strong community of ethical hackers that bring unique expertise to find vulnerabilities scanners and AI miss. With the built-in visibility and reporting HackerOne provides, organizations can protect their cloud environment against multiple threat vectors, including cloud misconfigurations, data exposures, subdomain takeovers, unauthorized access to applications, and many more.

There are three main HackerOne product offerings that can assist organizations looking to harden their cloud attack surface:

1. [HackerOne Assessments](#) brings a creative, community-led approach to cloud pentesting that gives organizations more coverage, real-time results, and seamless remediation workflows to find and fix vulnerabilities fast. HackerOne's [AWS-specific solutions](#) allow organizations to gain visibility into cloud-specific threats across cloud applications, APIs, IAM risks, serverless deployments, DNS management, and S3 issues by working

with background-checked, AWS-certified hackers. The vulnerability results and intelligence can also be seamlessly routed [from HackerOne to AWS Security Hub](#) for fast, effective security actions.

2. [HackerOne Bounty](#) minimizes the risk of cyberattacks by inviting ethical hackers to help organizations find and mitigate cloud security gaps.
3. [HackerOne Response](#) helps organizations implement a vulnerability disclosure policy to comply with regulations while arming security teams with vulnerability intelligence across a myriad of cloud-based assets.

See Our Additional Guides on Key Data Breach Topics

Together with our content partners, we have authored in-depth guides on several other topics that can also be useful as you explore the world of [data breaches](#).

Data Protection

Authored by Cloudian

- [GDPR Data Protection: Definitions and Practical Measures](#)
- [Office 365 Data Protection. It is Essential.](#)
- [How You Can Maintain Secure Data Storage](#)

Advanced Threat Protection

Authored by Cynet

- [Advanced Threat Detection: Catch & Eliminate Sneak Attacks](#)
- [Malware Prevention: A Multi-Layered Approach](#)
- [Zero-Day Attack Prevention: 4 Ways to Prepare](#)

AWS Backup

Authored by NetApp

- [AWS Database Backup in Hybrid Cloud & Cloud-Only Environments](#)
- [Understanding AWS Backup Pricing](#)
- [EBS to S3: Streamlining Data on AWS](#)

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a
hacker?

